

Daily Vulnerability Report - 2026-09-14

Window (UTC): 2026-09-13T12:06 to 2026-09-14T12:06 | Sources: NVD, CISA KEV, FIRST EPSS | Generated 2026-09-14 12:06:41 UTC

Total	KEV (exploited)	Critical	High	Medium	Low	Unscored	Watchlist
287	3	8	72	118	81	8	44

P1 - Act now (KEV / high EPSS)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85706	10.0	CRIT	Yes	0.012	gitlab:community edition and enterprise edition	GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.7 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions, an unauthenticated user could have read arbitrary files from the GitLab server due to improper path confinement and missing authentication enforcement in the repository commits API.
CVE-2026-82078	9.4	CRIT	Yes	0.017	papercut:papercut_mf, papercut:papercut_ng	An unsafe dynamic class loading vulnerability exists in the database connection utilities of PaperCut MF and PaperCut NG. The application instantiates database driver classes based on configurable driver names without validating against an allowlist of approved drivers. If an attacker can manipulate system configuration parameters, this enables the execution of arbitrary Java bytecode residing on the application c...
CVE-2026-81578	8.8	HIGH	Yes	0.016	papercut:papercut_mf, papercut:papercut_ng	An improper access control vulnerability exists in the web management interface of PaperCut MF and PaperCut NG. Under specific conditions, unauthenticated remote requests targeting administrative functions can trigger backend actions prior to the completion of access validation checks. This allows an unauthenticated remote attacker to modify certain system configurations.

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81648	10.0	CRIT				The CryptoPayment Gateway WordPress plugin from 1.2.1 to 1.2.2 does not apply an authorization check on one of its AJAX endpoints, allowing unauthenticated users to invoke administrative operations, including deleting arbitrary files on the server, overwriting the payment gateway configuration and recovering stored wallet credentials in cleartext.
CVE-2026-90898	9.8	CRIT				Bifrost registers MCP clients through its management API. A stdio client is a command plus args. Bifrost starts that program in the gateway the moment the client is added. No MCP handshake required. The default is governance.auth_config.is_enabled=false. Auth off means every caller is a local admin. One unauthenticated POST /api/mcp/client is enough to run a program as the Bifrost process user (appuser on the o...
CVE-2026-85192	9.4	CRIT				Joomla Extension - regularlabs.com - Authenticated, privileged remote code execution in Conditional Content extension for Joomla < 8.0.0 - Conditional Content Pro accepts inline PHP Condition Rules in article syntax. In affected versions, the PHP is passed to the Conditions evaluator without checking who authored the article. Joomla's normal Author text filter preserves the syntax, so publishing the article causes...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-90680	9.4	CRIT				A security flaw has been discovered in D-Link DIR-823G 1.0.2B05_20181207. The impacted element is the function strcpy of the file /HNAP1/SetStaticRouteSettings of the component HNAP1. The manipulation of the argument PAddress/SubnetMask/Gateway results in stack-based buffer overflow. The attack can be launched remotely.
CVE-2026-90692	9.4	CRIT				A vulnerability was detected in D-Link DIR-878 120B05. This affects the function SetDynamicDNSIPv6Settings of the component Dynamic DNS IPv6 Settings. The manipulation of the argument IPv6Address/Hostname results in stack-based buffer overflow. The attack may be launched remotely.
CVE-2026-90693	9.4	CRIT				A flaw has been found in D-Link DIR-878 120B05. This impacts the function SetWan3Settings of the component WAN Settings. This manipulation of the argument Primary/Secondary causes stack-based buffer overflow. Remote exploitation of the attack is possible.

Watchlist matches (other priorities)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-90776	8.7	HIGH				Nodemailer versions 9.1.0 through 10.0.4 contain a quadratic time complexity vulnerability in the addressparser component when parsing email addresses with RFC 5322 comments. Attackers can craft malicious email headers with comment-separated atoms to consume excessive CPU and block the Node.js event loop for several seconds, causing denial of service.
CVE-2026-12518	8.5	HIGH				A local privilege escalation vulnerability in the Logitech Logi Options+ updater service on Windows allows a low-privileged local user to execute arbitrary code as SYSTEM.
CVE-2026-68955	8.4	HIGH				The installer for Rakuten Kobo Desktop Application (Windows version) insecurely loads Dynamic Link Libraries. If there is a crafted DLL at the same directory when invoking the affected installer, arbitrary code may be executed with the privileges of the user who performed the installation.
CVE-2026-37008	8.1	HIGH				CrewAI before fb2323b offers a Python blocklist approach that operates at the wrong level of abstraction, a different vulnerability than CVE-2026-2275. Import-time blocking of module names does not address the availability of Python's complete object graph. For example, calling ctypes.CDLL(None) loads the C library without relying in any import statements. In other words, a within-process sandbox cannot merely acc...
CVE-2026-29811	7.7	HIGH				CyberPanel before 2.4.4 attempts to detect an "alais" domain (i.e., a second domain that serves the same content as a primary domain; normally spelled "alias") via an ORM query filter rather than a Python "if" statement.
CVE-2026-31278	7.7	HIGH				An issue in the /api/v2/setting/adserversetting endpoint of Suprema BioStar 2 before 2.9.12 and and BioStar X before 1.0.2 allows attackers to obtain Active Directory service account credentials in cleartext by supplying a crafted GET request.
CVE-2026-85189	7.5	HIGH				Joomla Extension - regularlabs.com - Privileged stored XSS via executable URL schemes in Modals extension for Joomla < 17.0.0 - Modals treats a destination using an executable browser URL scheme as an ordinary modal URL. The value can reach both the generated link and the iframe-loading path. Authored content can consequently become JavaScript in a visitor's browser without using Modals' separate Pro JavaScript Ev...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85191	7.5	HIGH				Joomla Extension - regularlabs.com - Privileged stored XSS via rtl-a-alias option in Tabs & Accordions extension for Joomla < 3.1.0 - Tabs & Accordions rewrites links matching an item alias into calls to its browser API. The affected renderer places the alias inside a quoted JavaScript argument in an HTML onclick attribute without securing both the JavaScript-string and HTML-attribute contexts. A crafted data-rtl-a-...
CVE-2026-88853	7.5	HIGH				Joomla Extension - regularlabs.com - Privileged stored XSS via event handler option in Modals Pro extension for Joomla < 17.0.0 - Modals Pro intentionally supports JavaScript Events such as on-open and on-closed. Affected versions do not distinguish trusted extension configuration from event code supplied in ordinary article content. A lower-privileged author can therefore use a documented executable feature which...
CVE-2026-90775	7.1	HIGH				PostGIS address_standardizer through 3.7.0 fails to validate the Weight parameter from caller-supplied rules tables before using it as an array index. Attackers can craft malicious rule rows with out-of-range Weight values to trigger out-of-bounds reads in the load_value array, causing the PostgreSQL backend process to crash and terminate all cluster sessions.
CVE-2026-16726	6.8	MEDI				Buffer overflow vulnerability in Panasonic Industry USB Driver for MINAS A5/A6 allows attackers to stop Windows.
CVE-2026-90522	5.5	MEDI				A vulnerability was determined in jaychouchannel Tourism-Management-System up to d984d172dceca907f8b447efbdb06dc233f7938d. Impacted is the function resetPass of the file UsersController.java of the component Password Recovery. This manipulation causes weak password recovery. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. Continious delivery with rolling releases ...
CVE-2026-90523	5.5	MEDI				A vulnerability was identified in jaychouchannel Tourism-Management-System up to 229956e20dbd4a80eeff14535e44d3099502af09. The affected element is an unknown function of the file travel/src/main/java/com/controller/UsersController.java of the component User Register Endpoint. Such manipulation of the argument UsersEntity leads to improper privilege management. The attack can be launched remotely. The exploit is pu...
CVE-2026-90584	5.5	MEDI				A weakness has been identified in TooTallNate Java-WebSocket up to 1.6.1. The impacted element is the function processFrameContinuousAndNonFin of the file Draft_6455.java of the component Fragmentation Handler. Executing a manipulation can lead to allocation of resources. The attack may be performed from remote. The exploit has been made available to the public and could be used for attacks. The pull request to fi...
CVE-2026-90619	5.5	MEDI				A vulnerability has been found in 0x4m4 HexStrike AI up to d689933ff579d839c676c82b231f8e98326c5f04. Impacted is an unknown function of the file hexstrike_server.py of the component Execute Endpoint. The manipulation of the argument code/script leads to os command injection. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. This product is using a rolling...
CVE-2026-90620	5.5	MEDI				A vulnerability was determined in 0x4m4 HexStrike AI up to d689933ff579d839c676c82b231f8e98326c5f04. The impacted element is an unknown function of the file hexstrike_server.py of the component API Command Endpoint. This manipulation causes missing authentication. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. Continious delivery with rolling releases is used by ...
CVE-2026-90690	5.5	MEDI				A weakness has been identified in 0x4m4 HexStrike AI up to d689933ff579d839c676c82b231f8e98326c5f04. The affected element is the function subprocess.Popen of the file hexstrike_server.py of the component API Tools Endpoint. Executing a manipulation of the argument additional_args/target/username/password/scan_type/payload can lead to os command injection. The attack can be launched remotely. The exploit has been m...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-90691	5.5	MEDI				A security vulnerability has been detected in 0x4m4 HexStrike AI up to d689933ff579d839c676c82b231f8e98326c5f04. The impacted element is the function FileOperationsManager of the file hexstrike_server.py of the component API Files Endpoint. The manipulation of the argument filename leads to path traversal. The attack may be initiated remotely. The exploit has been disclosed publicly and may be used. The project wa...
CVE-2025-63842	5.4	MEDI				A Cross-Site Scripting (XSS) vulnerability in the web backend for the Repetico app 1.9.7.31 for Android allows a remote authenticated user to execute arbitrary JavaScript code in the app's context via crafted input in the multiple-choice question text field.
CVE-2026-10556	5.3	MEDI				Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 fail to validate null entries in Microsoft Graph webhook notification payloads, which allows an unauthenticated attacker to crash the Microsoft Calendar plugin process and deny calendar integration service to all users on the instance via a crafted {{POST}} request to the public webhook endpoint.. Mattermost Advisory ID: ...
CVE-2026-88932	5.3	MEDI				multer is a Node.js middleware for handling multipart/form-data uploads. In versions 2.2.0 through 2.3.0, when a request using disk storage is aborted mid-upload, file writes that complete after multer has already run its abort cleanup are not removed, so each aborted upload can leave an orphaned file on disk. A remote unauthenticated attacker can repeatedly start and abort uploads to accumulate orphaned files and...
CVE-2026-90583	5.3	MEDI				A security flaw has been discovered in kagisearch smallweb up to 0ecb9c48edbf98dc7e934b54fbac43869e64b4cf. The affected element is the function index of the file app/sw.py of the component Query String Rendering. Performing a manipulation of the argument qs results in cross site scripting. The attack is possible to be carried out remotely. This product adopts a rolling release strategy to maintain continuous deliv...
CVE-2026-90563	5.1	MEDI				A vulnerability was determined in maliangnansheng bbs-springboot 3.0.0. This affects the function utils.toToc of the file ArticleController.java. This manipulation causes cross site scripting. The attack is possible to be carried out remotely.
CVE-2026-90569	4.8	MEDI				A flaw has been found in linlinjava litemall 1.5.0/1.6.0/1.7.0/1.8.0. This vulnerability affects the function AdminTopicController.validate of the file litemall-vue/src/views/items/topic/index.vue of the component Admin Topic Handler. This manipulation causes cross site scripting. The attack may be initiated remotely. The project was informed of the problem early through an issue report but has not responded yet.
CVE-2026-90570	4.8	MEDI				A vulnerability has been found in linlinjava litemall 1.4.0/1.5.0/1.6.0/1.7.0/1.8.0. This issue affects the function AdminGoodsService.validate of the file litemall-vue/src/views/items/detail/index.vue of the component Product Detail. Such manipulation of the argument detail leads to cross site scripting. The attack may be launched remotely. The project was informed of the problem early through an issue report but...
CVE-2023-40772	4.3	MEDI				A directory Traversal vulnerability in DataEase before 1.18.10 allows a remote attacker to obtain sensitive information via a a crafted request to the StaticResourceController.java component.
CVE-2026-89321	4.3	MEDI				Publishing limits the compressed size of a VSIX (ovsx.publishing.max-content-size, 512 MB by default) but nothing limited how large an entry becomes when opened. On the first request to /vscode/unpkg/{namespace}/{extension}/{version}/{path}, WebResourceService opened the entry with ZipFile.getInputStream() and passed the decompressed stream to Files.copy(), which ran to the end of the stream without counting b...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-90520	2.1	LOW				A vulnerability has been found in jaychouchannel Tourism-Management-System up to 84d8ec384f669df3985293dab293bb7b477efa64. This vulnerability affects unknown code of the file AuthorizationInterceptor.java of the component Authorization Interceptor. The manipulation leads to improper authorization. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. This pro...
CVE-2026-90521	2.1	LOW				A vulnerability was found in jaychouchannel Tourism-Management-System up to 8122bf020d91199eddf3ee02d1632a70a9a132. This issue affects some unknown processing of the file MenpiaodingdanController.java of the component CRUD. The manipulation of the argument ID results in authorization bypass. It is possible to launch the attack remotely. The exploit has been made public and could be used. This product takes the a...
CVE-2026-90581	2.1	LOW				A vulnerability was determined in cym1102 nginxWebUI up to 4.4.2. This issue affects the function MainController.autoUpdate of the file /adminPage/main/autoUpdate. This manipulation of the argument url causes code injection. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The pull request to fix this issue awaits acceptance.
CVE-2026-90594	2.1	LOW				A vulnerability was identified in wxiaoqi Spring-Cloud-Platform 3.0.1/3.1.0. This vulnerability affects the function PermissionService.checkUserPermission of the file /rpc/service/PermissionService.java of the component Permission Service. The manipulation leads to missing authorization. Remote exploitation of the attack is possible. The exploit is publicly available and might be used. The project was informed of ...
CVE-2026-90595	2.1	LOW				A security flaw has been discovered in wxiaoqi Spring-Cloud-Platform 1.0/2.2/3.0. This issue affects the function OnlineController.getOnlineInfo of the file aceModules/ace-admin/auth/controller/OnlineController.java. The manipulation results in missing authorization. The attack can be executed remotely. The exploit has been released to the public and may be used for attacks. The project was informed of the problem...
CVE-2026-90598	2.1	LOW				A vulnerability was detected in jaygajera17 E-commerce-project-springBoot up to 5e74a46b4b70623d0e4a0c9c4aee3bd1777185d2. The impacted element is the function UserController.updateUser of the file UserController.java. Performing a manipulation of the argument userId results in authorization bypass. It is possible to initiate the attack remotely. The exploit is now public and may be used. This product is using a ro...
CVE-2026-90622	1.9	LOW				A security flaw has been discovered in GNU libredwg 0.13.4. This impacts the function DWG_TABLE of the file src/dwg.spec of the component Layer Encoding. Performing a manipulation results in null pointer dereference. The attack needs to be approached locally. The exploit has been released to the public and may be used for attacks. Upgrading to version 0.14 will fix this issue. The patch is named f5b548c4c1697d66c3...
CVE-2025-64059	1.8	LOW				Grav 1.7.50.2 allows admins to enter JavaScript via the Home Page editor. NOTE: the relevance of this for stored XSS is disputed because admins are allowed to modify templates, install plugins, and upload other executable content.
CVE-2026-68570						Incorrect Authorization vulnerability in Apache Doris allows an authenticated user to bypass privilege checks and access data they are not authorized to read, resulting in unauthorized disclosure of information. This issue affects Apache Doris: from 2.0.0 through 2.1.*, from 3.0.0 through 3.0.*, from 4.0.0 before 4.0.8, and from 4.1.0 before 4.1.4. Users are recommended to upgrade to a fixed release (4.0.8 o...
CVE-2026-72524						Incorrect Authorization vulnerability in Apache Doris allows an authenticated user to bypass privilege checks and access or modify data they are not authorized to. This issue affects Apache Doris: from 3.1.0 through 3.1.*, from 4.0.0 through 4.0.7, and from 4.1.0 through 4.1.3. Users are recommended to upgrade to a fixed release (4.0.8 or 4.1.4), which fixes the issue.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82232						Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Apache Syncope. An administrator with adequate entitlements can achieve execution of arbitrary SQL via stacked queries, leveraging unsanitized sort clauses for Task search. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are re...
CVE-2026-86460						Cypher injection vulnerability in the Neo4j persistence layer when processing some FIQL search conditions. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrade to version 4.0.8 / 4.1.3, which fix this issue.
CVE-2026-87779						Insertion of sensitive information into log file vulnerability in Apache Syncope. When AES key of non-standard length (not 16/24/32 bytes) is configured, Syncope will pad the provided value with random characters. The resulting key value is logged. This issue affects Apache Syncope: from 3.0.15 through 3.0.16, from 4.0.3 through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrade to versi...
CVE-2026-87785						Authentication bypass by spoofing vulnerability in Apache Syncope. When the configured JWKS settings for internal JWT authentication are disclosed (at least protocol and key), an attacker can spoof another user's privileges after completing a successful authentication and obtaining a valid JWT. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4...
CVE-2026-87802						Improper verification of cryptographic signature vulnerability in Apache Syncope. When SRA is configured for OAuth 2.0 without JWKS set URI assigned, an attacker can forge arbitrary JWTs to impersonate any user identity and permissions, gaining full access to services proxied by SRA. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4.1.2. Us...

P3/P4 items (278) are in the Excel report. Unsourced CVEs are newly published and awaiting NVD analysis; re-check tomorrow's report.